



UNIVERSITATEA
LUCIAN BLAGA
— DIN SIBIU —

FACULTATEA DE
ȘTIINȚE ECONOMICE

BACHELOR THESIS

Understanding What You Are Clicking: Automated Analysis and Comparison of Website Privacy Policies

Scientific Coordinator:

Associate Professor, Ph.D. Eduard Alexandru STOICA

Student:

Diana-Maria MITEA
Business Informatics

SIBIU 2026

Summary

Continuous collection of personal data is essential to the current digital economy. Although laws such as the General Data Protection Regulation (GDPR) require "Privacy by Default" and explicit authorization, their practical implementation has produced a defective and often misleading ecosystem. Businesses frequently rely on formal privacy policies and misleading "Dark Patterns" in cookie banners, leading to "compliance theatre" - websites that appear to comply with regulations while still collecting data without valid consent. End users do not currently have the means to verify whether a website's technical tracking practices comply with its legally declared privacy statements.

This thesis describes the development and evaluation of Privacy Policy Analyzer & Cookie Trax, a client-side browser extension designed to bridge this gap. The application uses a dual-engine architecture. A Natural Language Processing (NLP) module analyzes legal documents, assesses privacy claims, and generates a measurable risk score. At the same time, a dynamic browser storage scanner evaluates live tracking payloads and checks for pre-consent tracking violations in HTTP cookies and HTML5 Web Storage APIs. These streams are then cross-referenced by a discrepancy engine to identify fabricated consent architectures.

When tested against 15 heavily frequented global domains, the application revealed widespread non-compliance. Key findings include sophisticated storage-evasion techniques that bypass standard cookie blocking (TikTok), unverifiable server-side processing that limits users' data autonomy (Meta, OpenAI), and fabricated consent states in which platforms pre-initialize tracking and ignore explicit opt-outs (Temu).



Tabel of Contents

1. Introduction	1
1.1 Background and Motivation	1
1.2 Problem Statement	1
1.3 Research Objectives	1
1.4 Structure of the Thesis	2
2. Theoretical Framework	3
2.1 The Regulatory Landscape of Digital Privacy	3
2.1.1 The General Data Protection Regulation (GDPR)	3
2.1.2 The ePrivacy Directive ("The Cookie Law")	3
2.2 Technical Mechanics of Digital Tracking	3
2.2.1 HTTP Cookies and Third-Party Injection	4
2.2.2 Modern Evasion: HTML5 Web Storage APIs	4
2.2.3 Stateless Tracking: Browser Fingerprinting	4
2.3 Deceptive Design and Compliance Evasion	5
2.3.1 The Taxonomy of Dark Patterns	5
2.3.2 The Phenomenon of "Compliance Theater"	5
2.4 The Role of Automated Auditing	5
3. Methodology	6
3.1 System Architecture and Design Justification	6
3.2 Contextual Keyword Extraction and Risk Tiering	6
3.3 Dynamic Cookie Analysis Integration	6
3.4 Ethical Considerations and Data Minimization in Tool Development	7
4. Results	8
4.1 Benchmark Dataset Selection	8
4.2 Textual Analysis Metrics and Risk Tiering	8
4.2.1 Aggregate Keyword Frequency and Categorical Distribution	9
4.2.2 Extraction Limitations and Architectural Edge Cases	11
4.3 Browser Cookie Detection & Baseline Auditing	11
4.4. Visual Diagnostics: The Application Interface	12
4.5 Live DOM Auditing: Capturing Evasion Tactics	13
4.6 Dark Pattern Typology in Consent Banners	14
5. Discussion	15
5.1 Synthesis of Empirical Findings	15
5.2 Architectural Evasion: The Illusion of Consent	15
5.2.1 Fabricated Consent States and Dark Patterns (Temu)	15



5.2.2 Evasive Local Storage Architectures (TikTok)	15
5.2.3 Unverifiable Architectures and Ignored Opt-Outs (Meta and OpenAI)	16
5.3 The Economic Drivers of Compliance Theatre: Real-Time Bidding (RTB)	16
5.4 Implications for Regulatory Frameworks	17
5.5 The Necessity of Automated Client-Side Auditing	17
6. Conclusions	18
6.1 Summary of Research and Findings	18
6.2 Technical Limitations of the Developed Application	18
6.3 Future Work and Research Directions	19
6.4 Final Concluding Remarks	19
References	20
Appendices	22



List of Figures and Tables

<i>Figure 1. Aggregate distribution of privacy flags extracted across the benchmark dataset (N=15).</i>	11
<i>Figure 2. Application dashboard rendering a comparative compliance analysis between a low-risk domain (down) and a high-risk domain (up)</i>	12
<i>Figure 3. Diagnostic view of pre-consent local storage injection, demonstrating tracking initialization prior to user authorization.</i>	13
<i>Figure 4. Example of Visual Interference and obstruction utilized within a Consent Management Platform.</i>	14
<i>Table 1. Benchmark Dataset of Analyzed Privacy Policies (N=15)</i>	8
<i>Table 2. Automated Textual Analysis Metrics by Domain</i>	9
<i>Table 3. Top 5 Most Frequent Privacy Keywords Across All Domains</i>	10
<i>Table 4. Pre-Consent Tracking Baseline (Zero-Interaction State)</i>	12



List of Abbreviations

- **API / APIs:** Application Programming Interface / Interfaces
- **CMPs:** Consent Management Platforms
- **CSS:** Cascading Style Sheets (used as CSS in the methodology)
- **DOM:** Document Object Model
- **DPA / DPAs:** Data Protection Authority / Data Protection Authorities
- **GDPR:** General Data Protection Regulation
- **GPC:** Global Privacy Control
- **HTML / HTML5:** HyperText Markup Language
- **HTTP:** Hypertext Transfer Protocol
- **LLM:** Large Language Model
- **NLP:** Natural Language Processing
- **PET:** Privacy-Enhancing Technology
- **Regex:** Regular Expressions
- **RTB:** Real-Time Bidding
- **SPA:** Single-Page Application
- **UI:** User Interface
- **UX:** User Experience
- **W3C:** World Wide Web Consortium



1. Introduction

1.1 Background and Motivation

The extraction, commercialization, and algorithmic analysis of personal data build the foundation of the modern digital economy. Two examples of the strict guidelines that international regulatory bodies have developed in response to the rampant tracking practices used by digital platforms are the General Data Protection Regulation (GDPR) of the European Union and the ePrivacy Directive (European Parliament and Council of the European Union, 2002) (European Parliament and Council of the European Union, 2016). These frameworks' legal purpose is to uphold the principle of "Privacy by Design and by Default," which requires that all corporations be very clear about their intent to use and store the data collected and that the procedures used to obtain consent for non-essential tracking technologies are unambiguous.

The integration of mandatory privacy policies and cookie consent banners has completely transformed digital interfaces in response to these regulatory requirements. In theory, these consent management platforms (CMPs) enable people to control their digital footprints by eliminating the knowledge imbalance between businesses and customers. However, a seriously defective and frequently misleading privacy ecosystem has resulted from the practical use of these compliance methods.

1.2 Problem Statement

There is a substantial operational gap between the company's technological compliance and regulatory requirements, despite strong legislative efforts. There are two main ways that users are alienated as a result of this ongoing gap:

First, written privacy policies create significant information friction. They are written as comprehensive legal documents, often tens of thousands of words long, making them incomprehensible to the typical user. (Wilson, et al., 2016). As a consequence, it is almost impossible for people to audit the data collection, third-party sharing, and retention policies of the many different domains they deal with on a regular basis.

Second, the way consent systems are put into practice often goes against the main ideas of the GDPR because of something called "compliance theater." Many organizations use "Dark Patterns," which are manipulative design choices, to hide opt-out options and push users to agree (Gray, et al., 2018) (Nouwens, et al., 2020). Recent studies show there is a gap between the user interface (UI) and the browser's Document Object Model (DOM). Many websites begin tracking data before getting user consent, which goes against default privacy settings, or they ignore users who say no (Matte, et al., 2020). End users do not yet have intuitive, real-time diagnostic tools to evaluate whether a domain's technological tracking behavior adheres to its legally disclosed privacy declarations (Zaeem, et al., 2020).

1.3 Research Objectives

The thesis's primary objective is to bridge the systemic gap between theoretical privacy claims and practical technical implementations. To accomplish this, the study presents the algorithmic development, architectural design, and concrete analysis of a client-side browser extension that protects privacy (Privacy Policy Analyzer & Cookie Trax). The specific, measurable objectives of this research are:



- **Automated Static Analysis:** To develop a client-side, lightweight Natural Language Processing (NLP) system that can categorize risk vectors (such as third-party data brokering), instantly read complex privacy paperwork, and produce a concrete privacy risk metric.
- **Dynamic Storage Auditing:** To provide a real-time browser storage scanner that can identify both deceptive local storage architectures (like localStorage) and conventional HTTP cookies, with a focus on monitoring for pre-consent tracking violations.
- **Discrepancy Engine Implementation:** To present a cross-referencing module that explicitly indicates ignored opt-outs and tests the logical consistency between a domain's consent banner interface, live tracking payload, and theoretical policy claims.
- **Empirical Evaluation:** To test the developed application against a benchmark dataset of highly frequented global websites, providing data-driven feedback on the present level of digital privacy compliance.

1.4 Structure of the Thesis

In order to methodically handle the study objectives, this thesis is divided into six main chapters. After this introduction, Chapter 2 (Theoretical Framework) offers a thorough analysis of the GDPR's legal underpinnings, the technical aspects of web monitoring, and the Dark Pattern taxonomy. The application's software architecture is described in Chapter 3 (Methodology), which also provides justification for using a client-side JavaScript engine inside the Manifest V3 framework. The quantitative information and baseline measurements obtained from assessing the benchmark dataset are presented in Chapter 4 (Results). Chapter 5 discusses these empirical results and uses specific architectural case studies to show how common fake consent is. Chapter 6 then summarizes the research findings, describes the application's technological limits, and suggests areas for future development.



2. Theoretical Framework

The theoretical and technological basis of the empirical research are established in this chapter. It investigates the systematic use of misleading user interface designs that evade legal compliance, analyses the current regulatory environment governing digital privacy, and breaks down the underlying web technologies used for the collection of information.

2.1 The Regulatory Landscape of Digital Privacy

Strong regulatory frameworks intended to safeguard consumer privacy have been required due to the data broking industry's exponential growth. The General Data Protection Regulation (GDPR) and the ePrivacy Directive are two overlapping pieces of legislation that largely govern this in the European Union.

2.1.1 The General Data Protection Regulation (GDPR)

The GDPR, introduced in 2018, is widely considered the most comprehensive data protection law in the world (European Parliament and Council of the European Union, 2016). It defines privacy as a fundamental human right rather than just a consumer preference. Some key principles of the GDPR are especially relevant to our discussion:

- **Transparency and Information Asymmetry:** Article 12 says that business privacy policies must be brief, clear, easy to understand, and easy to find. Using complex legal language in privacy documents does not meet this standard.
- **Conditions for Consent:** Article 7 says that consent must be given freely, clearly, and with full understanding. The law also states that revoking permission should be just as easy as granting it, but this is often overlooked in today's online systems
- **Privacy by Design and by Default:** Article 25 states that data controllers must set up technical systems so that, by default, only the personal data needed for a specific reason is processed. This means non-essential tracking tools cannot be used until the user clearly agrees.

2.1.2 The ePrivacy Directive ("The Cookie Law")

The ePrivacy Directive regulates electronic communications and the use of tracking technologies, while the GDPR governs personal data more broadly. Except for strictly necessary functional operations, a website may not read from or write information, such as cookies, to a user's terminal device without prior consent (European Parliament and Council of the European Union, 2002). Together, the GDPR and the ePrivacy Directive require websites to use Consent Management Platforms (CMPs), commonly known as cookie banners.

2.2 Technical Mechanics of Digital Tracking

Understanding how digital tracking works is important for spotting compliance issues. The Hypertext Transfer Protocol (HTTP), which runs the web, is "stateless." This means the server does not remember what users did before. To keep track of things like whether a user is logged in, developers use browser storage APIs.

2.2.1 HTTP Cookies and Third-Party Injection

Cookies are small, stateful text files injected into the browser's memory by a web server. (Barth, 2011). They are categorized by provenance and duration:

- **First-Party vs. Third-Party:** First-party cookies originate from the website being visited, such as temu.com, and primarily ensure the proper functioning of the site. In contrast, third-party cookies are set by external domains, including google-analytics.com or facebook.com, via embedded code on the visited website. These third-party cookies enable tracking of user activity across multiple websites (Englehardt & Narayanan, 2016).
- **Session vs. Persistent:** Session cookies are temporary and are deleted when the browser is closed. In contrast, persistent cookies remain for extended periods, sometimes exceeding one year, enabling websites to monitor user activity over time.

2.2.2 Modern Evasion: HTML5 Web Storage APIs

As browser vendors (such as Apple's Safari and Mozilla's Firefox) began automatically blocking third-party HTTP cookies to enhance user privacy, data aggregators evolved their methodologies. Modern platforms frequently bypass standard HTTP cookies entirely, utilizing HTML5 Web Storage APIs (localStorage and sessionStorage). (World Wide Web Consortium, 2016).

Client-side JavaScript is utilized to directly query and manipulate data in localStorage, in opposition to cookies, which are automatically linked to HTTP requests. Given this architecture, developers can store enormous volumes of tracking IDs locally, frequently bypassing legacy compliance checks and simple cookie-blocking extensions. (Al-Rousan, et al., 2019) (Rodriguez & Posegga, 2018).

2.2.3 Stateless Tracking: Browser Fingerprinting

While HTTP cookies and HTML5 Web Storage represent stateful tracking mechanisms—meaning they actively store data on the user's terminal equipment—the digital advertising ecosystem is increasingly migrating toward "stateless" tracking techniques to evade regulatory scrutiny. The most prominent of these methods is browser fingerprinting.

Unlike traditional cookies, fingerprinting does not require the website to store a text file on the user's device. Instead, the website utilizes background JavaScript to quietly query the user's browser for hundreds of specific configuration details (Mowery & Shacham, 2012). The operating system, screen resolution, installed system fonts, time zone, language settings, and even the particular rendering properties of the device's graphics card are examples of these data fragments. (Canvas fingerprinting).

The combination of these small data elements generates a unique cryptographic hash, or "fingerprint," capable of identifying a user with over 99% accuracy. Fingerprinting totally avoids conventional cookie-blocking extensions and local storage audits because it depends on the device's intrinsic properties rather than injected data. Fingerprinting is extremely troublesome from a regulatory standpoint under the GDPR; it functions hidden, provides no technological means for the user to "clear" or remove the tracker, and makes consent verification nearly impossible. Although the Privacy Policy Analyzer & Cookie Trax's current version concentrates on stateful storage APIs, it is crucial to recognize the growing trend of stateless fingerprinting in order to comprehend the entire range of technical evasion techniques used by modern domains.



2.3 Deceptive Design and Compliance Evasion

The digital economy's default data-harvesting model was upended by the requirement to get express consent. To sustain high opt-in rates, the industry responded by widely implementing hostile UI/UX tactics, which are officially known as "Deceptive Design" or "Dark Patterns."

2.3.1 The Taxonomy of Dark Patterns

Dark Patterns refer to user interface designs that leverage cognitive biases to influence user choices and obtain consent, frequently compromising individual autonomy (Gray, et al., 2018) (Kocyigit, et al., 2023). Common manifestations within Consent Management Platforms include:

- **Visual Interference:** Bright, contrasting colours should be applied to the "Accept All" button to enhance its visibility, whereas the "Decline" and "Manage Settings" options should utilize muted, low-contrast text (Soe, et al., 2020).
- **Click Fatigue (Obstruction):** Users are able to accept all tracking with a single click, whereas rejecting tracking requires navigating through multiple menus.
- **Confirm shaming:** Utilizing emotionally manipulative language to guilt the user into accepting data extraction.

2.3.2 The Phenomenon of "Compliance Theater"

Besides simple UI manipulation, a more serious technical violation exists: **compliance theatre**. This happens when a Consent Management Platform provides a legally compliant interface (e.g., "Accept" and "Decline" buttons) but is structurally separated from the website's execution engine.

The CMP serves only as a visual placebo in these architectures. According to research study, platforms that engage in compliance theatre will either keep monitoring threads active even after the user actively initiates an opt-out event, or they will execute tracking payloads synchronously with the initial page load (violating Privacy by Default). (Trevisan, et al., 2019) (Utz, et al., 2019).

2.4 The Role of Automated Auditing

For the average internet user, the combination of lengthy privacy documentation and deceptive tracking technologies has created an overwhelming burden. Advanced legal literacy and in-depth technical knowledge of web development and browser console analysis are necessary for manual corporate compliance verification.

This systemic disparity created the demand for developing specialized, automated auditing instruments. Client-side software can restore transparency by parsing semantic legal text with Natural Language Processing (NLP) and auditing current DOM activities using dynamic browser API monitoring. These programs assess both theoretical compliance (textual policy analysis) and practical execution (cookie and storage tracking), completely eliminating the phenomenon of compliance theatre.

3. Methodology

3.1 System Architecture and Design Justification

In order to achieve the study's goal of providing users with real-time, automated examination of website privacy rules, a localized client-side architecture was created. The application has been developed as a browser extension in compliance with Manifest V3 requirements. Its implementation utilizes HTML, CSS, and standard JavaScript (Google, 2026) (Ling, et al., 2022). Natural language processing and core analysis use a dedicated JavaScript engine, `analyzer.js`, that runs entirely in the browser. This architectural decision is justified by two primary factors:

1. **Data Privacy and Security:** The user's browsing data is never sent to an external server due to local processing of the policy text and cookie scanning (Sanchez-Rola, et al., 2017). This approach aligns closely with the fundamental privacy principles underlying the application.
2. **Performance and Scalability:** The program efficiently analyzes large text files, including those exceeding 100,000 characters, by partitioning them into smaller segments and leveraging the client's local computing resources. This process utilizes Web Workers (`analyzer-worker.js`) (Castro, 2021). This prevents browser interface freezing, eliminates network latency, and avoids external server hosting dependencies.

3.2 Contextual Keyword Extraction and Risk Tiering

Instead of using simple string matching, which is prone to false positives, the fundamental text analysis uses an internal, rule-based computational engine. (Adhikari, et al., 2025). The process consists of dividing the extracted privacy policy into individual sentences and subsequently evaluating each sentence within its local context. This approach considers the target sentence along with the immediately preceding and following sentences.

The program analyzes text using Regular Expressions (Regex) to identify privacy-related phrases from a predefined list. For a more granular assessment, it categorizes these phrases into three confidence levels: critical, moderate, and weak. Additionally, the program evaluates contextual information to verify the accuracy of the results:

- **Negation:** The presence of words like "not" or "never" within the context window neutralizes penalty scores for specific keywords (e.g., "we do not sell data").
- **Collection Type:** The algorithm distinguishes between mandatory data collection (e.g., "we require") and optional data collection (e.g., "you may choose"), weighting them differently in the final mathematical privacy score.

3.3 Dynamic Cookie Analysis Integration

A supplementary methodology was used to examine the website's actual monitoring behaviour in order to confirm the statements provided in the text of a privacy policy. The program extracts all active cookies linked to the current domain using the Chrome Cookies API.

This dynamic auditing phase is critical because static code analysis is fundamentally insufficient for detecting modern web trackers. Many tracking payloads are not hardcoded into the initial HTML response; rather, they are injected asynchronously via third-party JavaScript execution only after the page has fully rendered. To capture this ephemeral



runtime behavior, the cookie-analyzer.js module actively queries the Chrome Cookies API while simultaneously scanning HTML5 Web Storage (local Storage and sessionStorage). This dual-pronged extraction ensures the application can detect sophisticated evasion tactics where data brokers attempt to bypass traditional cookie-blocking extensions by storing persistent identifiers directly within the browser's local cache.

Once the active storage payloads are extracted, the categorization process relies on a robust signature-matching heuristic. The algorithm cross-references the captured cookie names and storage keys against a continuously updated dictionary of known telemetry footprints (such as `_ga` for Google Analytics or `_fbp` for Meta Pixel), sorting them into Tracking, Analytics, Advertising, Functional, and Social categories. Finally, the methodology utilizes a discrepancy engine that serves as the logical bridge between the application's two core modules. It mathematically translates the theoretical NLP text score and the empirical live storage data into a unified compliance metric. For example, if advertising cookies are detected by the API, but the text analyzer finds no mention of third-party sharing in the policy, the system flags this as a high-severity privacy risk. By automating this cross-referencing, the engine can definitively identify and flag instances of "compliance theatre," providing verifiable proof of GDPR violations.

3.4 Ethical Considerations and Data Minimization in Tool Development

It was essential that the program itself not unintentionally create new privacy risks when creating a Privacy-Enhancing Technology (PET) intended to evaluate corporate data practices. Cloud-based processing architectures, which send the user's browsing history or the targeted website's Document Object Model (DOM) to a remote server for analysis, are frequently used by conventional online auditing tools and commercially available browser extensions.

The Privacy Policy Analyzer & Cookie Trax was designed completely as a localized, zero-trust solution to guarantee absolute conformity to the GDPR's Data Minimization principle. By keeping all processing strictly on the client side, the extension eliminates the inherent vulnerabilities associated with cloud-based sub-processors, such as data interception during transit or unauthorized data retention by third-party analytics APIs. While this architectural choice shifts the computational load onto the user's local hardware, the implementation of asynchronous Web Workers effectively mitigates any potential browser performance degradation. Ultimately, this approach proves that robust, real-time privacy verification does not require the sacrifice of user data sovereignty, establishing a highly scalable and ethical model for future privacy-enhancing technologies (PETs) within the field of business informatics.



4. Results

4.1 Benchmark Dataset Selection

A benchmark dataset of website policies was created in order to methodically assess the application's efficiency, scalability, and correctness. The chosen sample (N=15) includes popular domains from a variety of international industries. This variety is essential for evaluating the application against different web development architectures, business transparency standards, and regulatory settings.

The dataset includes domains from technology and artificial intelligence (Microsoft, Google, OpenAI, Anthropic), social media (Meta, LinkedIn, TikTok), e-commerce (Temu, Amazon Jobs, Shein), information and media (Wikimedia, The New York Times), design software (Canva), and government (USA.gov).

The dataset used for the primary textual analysis is described in Table 1, along with the industrial sector and the extracted privacy policy text's raw character length. With text lengths ranging from 185 characters (Samsung) to 78,366 characters (The New York Times), the application's asynchronous processing and chunking capabilities via Web Workers were thoroughly tested.

Table 1. Benchmark Dataset of Analyzed Privacy Policies (N=15)

Domain Name	Industry Sector	Policy (Characters)	Length
help.nytimes.com	Media / News	78,366	
policies.google.com	Technology / Search	64,205	
www.canva.com	Software / Design	63,962	
www.temu.com	E-commerce	60,727	
foundation.wikimedia.org	Information / Non-Profit	42,632	
www.linkedin.com	Social Media / Professional	41,565	
www.meta.com	Social Media	40,816	
www.anthropic.com	Technology / AI	34,632	
www.microsoft.com	Technology / Software	31,040	
openai.com	Technology / AI	28,747	
www.tiktok.com	Social Media	28,174	
www.sheingroup.com	E-commerce	24,121	
www.amazon.jobs	E-commerce / Corporate	9,510	
www.usa.gov	Government	4,400	
privacy.samsung.com	Technology / Electronics	185	

Source: Author's own research based on application data extraction.

4.2 Textual Analysis Metrics and Risk Tiering

Quantifying the privacy risk present in a certain policy language is the main goal of the application's static analysis module. By looking for categorized keywords (Data Collection, Third-Party Sharing, User Rights, Data Retention, and Consent Requirement), the client-side NLP engine assessed the benchmark dataset. The program generated a final Privacy

Score on a scale of 1 to 10 after processing these keywords via a contextual negation engine to avoid false positives. A score of 1 denotes serious privacy hazards marked by extensive data collection and limited user rights, whereas a score of 10 denotes ideal, transparent privacy procedures.

Table 2 displays the quantitative metrics produced by the text analysis engine across all 15 domains.

Table 2. Automated Textual Analysis Metrics by Domain

Domain	Data Collection Flags	Third-Party Sharing Flags	User Rights Flags	Final Privacy Score
www.usa.gov	3	2	4	10 / 10
foundation.wikimedia.org	22	27	60	10 / 10
www.microsoft.com	33	23	64	10 / 10
openai.com	25	27	54	10 / 10
www.anthropic.com	21	39	68	10 / 10
www.canva.com	61	67	117	10 / 10
www.amazon.jobs	3	11	18	10 / 10
www.temu.com	100	84	114	10 / 10
www.sheingroup.com	27	24	60	10 / 10
privacy.samsung.com	1	0	0	10 / 10
help.nytimes.com	82	132	142	9 / 10
policies.google.com	110	69	109	8 / 10
www.tiktok.com	46	43	41	6 / 10
www.meta.com	78	66	45	1 / 10
www.usa.gov	3	2	4	10 / 10

Source. Author's own research.

Several unique patterns in digital privacy documentation are revealed by the dataset. With a score of 1/10, Meta (www.meta.com) was determined to be the dataset's highest-risk policy. In contrast to a low emphasis on user rights (45 occurrences), this assessment was motivated by a disproportionately high volume of data collection flags (78 occurrences) and third-party sharing flags (66 occurrences).

On the other hand, media websites like The New York Times (help.nytimes.com) produced the largest number of Third-Party Sharing flags (132 instances) in the whole dataset. However, because the policy places a strong emphasis on User Rights (142 flags) and uses "optional" contextual keywords rather than "mandatory" ones, the computational engine dynamically balanced the final score to a 9/10. This shows that instead of depending only on frequency, the engine can assess the context of data usage.

4.2.1 Aggregate Keyword Frequency and Categorical Distribution

The tool offered a macro-level perspective on industry-standard terminology in addition to specific policy ratings. The program processed thousands of individual texts in all 15 areas. "Data Collection" and "User Rights" are the most extensively recorded categories, according

to a frequency distribution analysis, underscoring the conflict between corporate data collection and GDPR-mandated disclosures.

Table 3. Top 5 Most Frequent Privacy Keywords Across All Domains

Rank	Keyword Phrase	Category	Total Occurrences	Implication
1	"Collect"	Data Collection	283	Indicates ubiquitous, proactive data harvesting across all sectors.
2	"Share"	Third-Party Sharing	212	Highlights the highly interconnected nature of digital data brokering.
3	"Access"	User Rights	200	Reflects standardized compliance language required by GDPR (Right to Access).
4	"Consent"	User Rights / Consent	179	Utilized to establish a legal basis for processing user data.
5	"Location"	Data Collection	68	Demonstrates a high demand for geospatial tracking, particularly in tech and social media.

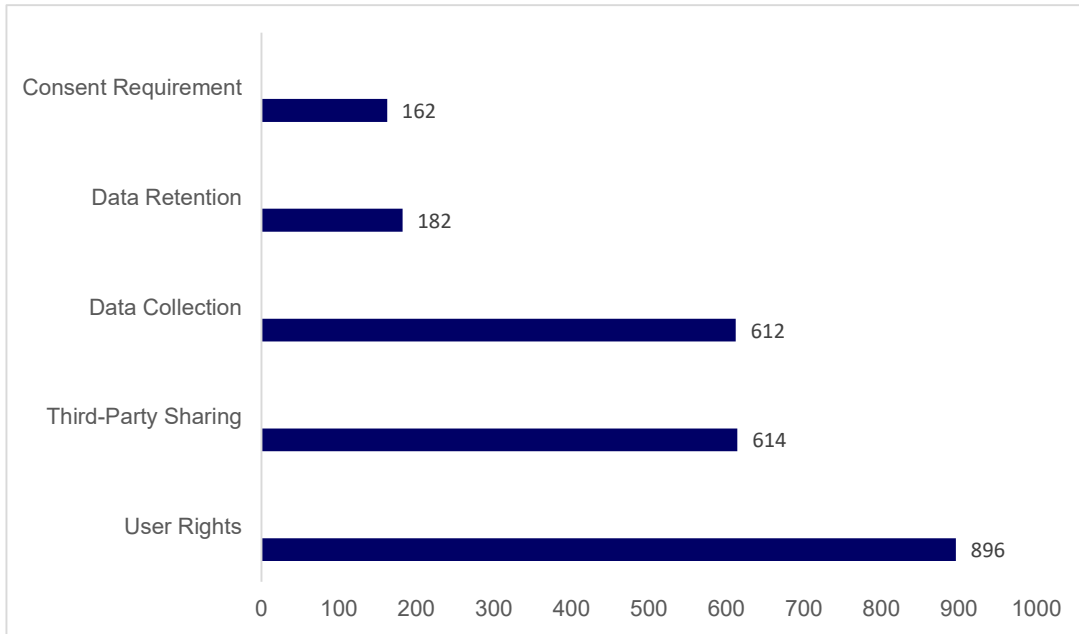


Figure 1. Aggregate distribution of privacy flags extracted across the benchmark dataset (N=15).

4.2.2 Extraction Limitations and Architectural Edge Cases

A structural flaw in automatic text extraction was also brought to light by the testing procedure. Samsung's policy (privacy.samsung.com) only produced 185 characters, which led to a single data collection flag and an artificially perfect score of 10/10. When websites use stringent "Cookie Walls" or significantly rely on dynamic client-side rendering frameworks (like React or Angular), the policy content is not instantly accessible in the HTML Document Object Model (DOM) at initial page load. This edge case demonstrates that even though the contextual NLP algorithm is very accurate, a full privacy audit requires the secondary dynamic cookie analysis module because pure textual analysis is insufficient.

4.3 Browser Cookie Detection & Baseline Auditing

A structural flaw in automatic text extraction was also brought to light by the testing procedure. Samsung's policy (privacy.samsung.com) only produced 185 characters, which led to a single data collection flag and an artificially perfect score of 10/10. When websites use stringent "Cookie Walls" or significantly rely on dynamic client-side rendering frameworks (like React or Angular), the policy content is not instantly accessible in the HTML Document Object Model (DOM) at initial page load. This edge case demonstrates that even though the contextual NLP algorithm is very accurate, a full privacy audit requires the secondary dynamic cookie analysis module because pure textual analysis is insufficient.

Table 4 presents the findings of this pre-consent baseline audit. The data conclusively demonstrates a widespread failure to adhere to "Privacy by Default" regulations.

Table 4. Pre-Consent Tracking Baseline (Zero-Interaction State)

Domain	Consent Banner Active?	Total Trackers Found	High-Risk Trackers	Pre-Consent Privacy Score
www.facebook.com	Yes	1	1 (Social/Tracking)	82 / 100
openai.com	Yes	4	4 (Analytics/Social)	81 / 100
www.tiktok.com	Yes	52	44 (Social/Tracking)	30 / 100
www.temu.com	Yes	14	8 (Tracking/Ads)	27 / 100

Source: Dynamic auditing via the Cookie Trax application.

As shown in Table 4, all tested domain-initiated tracking payloads were sent before user approval, indicating systemic noncompliance with default privacy standards.

4.4. Visual Diagnostics: The Application Interface

The Privacy Policy Analyzer & Cookie Trax was created using a risk-tiering, traffic-light-inspired graphical user interface (GUI) to successfully close the gap between complicated legal material and user comprehension. Through the extension's popup dashboard, the end-user is shown the combined empirical findings of the dynamic cookie auditing and the NLP scoring.

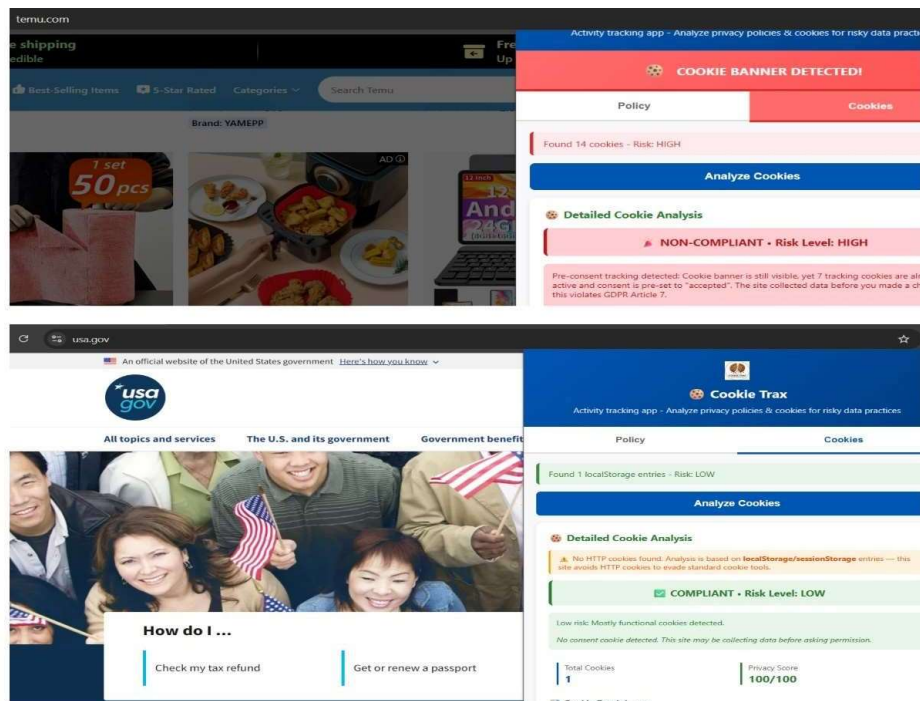


Figure 2. Application dashboard rendering a comparative compliance analysis between a low-risk domain (down) and a high-risk domain (up)

As illustrated in Figure 2, the interface immediately alerts the user to the underlying technical reality of the domain. By visualizing the discrepancy between the stated privacy score and the live tracking payload, the application successfully neutralizes the information friction caused by verbose legal texts.

To achieve this reduction in cognitive load, the dashboard is structurally bifurcated into two primary diagnostic views: the 'Policy' tab and the 'Cookies' tab. The 'Policy' interface distils the dense, multi-page legal document into a singular, quantifiable score out of 100, explicitly highlighting the exact frequency of critical risk flags (such as third-party data sales or location tracking). Conversely, the 'Cookies' interface provides a real-time, categorized ledger of the browser's storage APIs, sorting active payloads into Functional, Analytics, or Tracking categories.

Furthermore, the implementation of the traffic-light heuristic—Red for High Risk/Non-Compliant, and Green for Compliant—serves as a critical translation layer. Average internet users lack the technical literacy required to interpret raw Document Object Model (DOM) events, background JavaScript executions, or JSON-formatted web storage strings. By rendering these invisible background processes into immediate, colour-coded alerts (such as the explicit "COOKIE BANNER DETECTED" warning juxtaposed against the number of active trackers), the application bridges the gap between complex software engineering and user accessibility. This design paradigm ensures that digital autonomy is not restricted to technical experts, effectively democratizing data privacy oversight.

4.5 Live DOM Auditing: Capturing Evasion Tactics

Demonstrating the application's capacity to identify evasive tracking designs, particularly pre-consent local storage injections, was a crucial part of the outcomes. The application's background scripts recorded the precise time tracking payloads circumvented the Consent Management Platform (CMP) in order to demonstrate the existence of "compliance theatre."

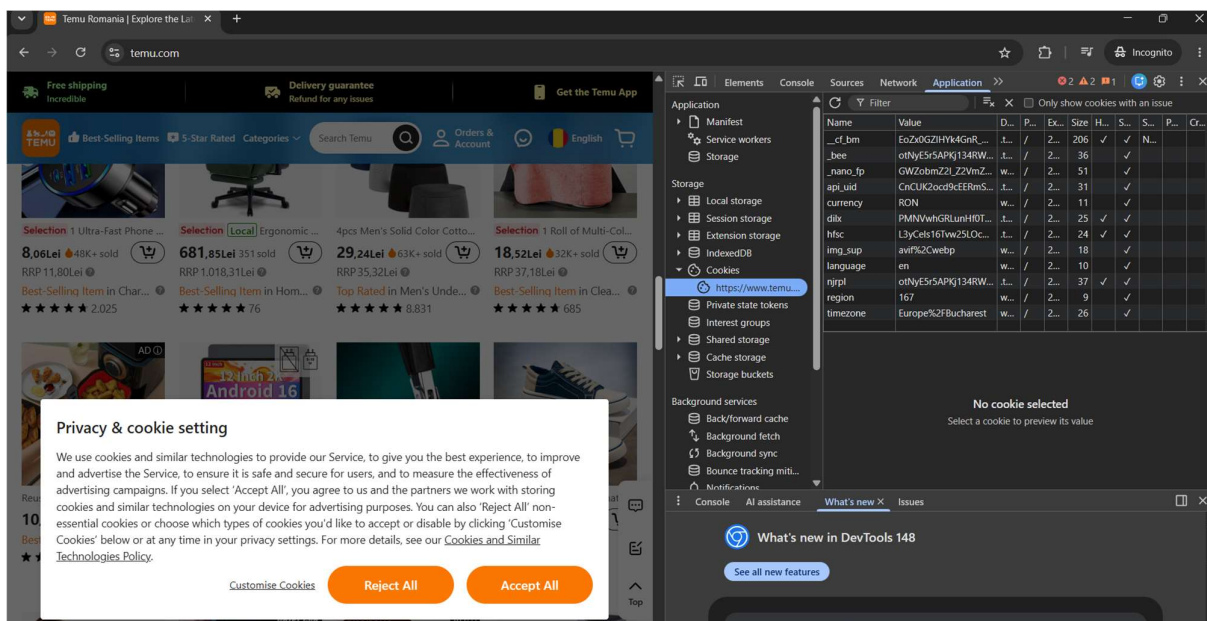


Figure 3. Diagnostic view of pre-consent local storage injection, demonstrating tracking initialization prior to user authorization.

Figure 3 provides empirical proof of the compliance evasion detailed in Chapter 2. While the user interface displays a pending consent state, the underlying Document Object Model

(DOM) and storage APIs have already been compromised. The application's ability to expose these hidden payloads in real-time validates the necessity of client-side dynamic auditing over traditional, manual policy reviews.

4.6 Dark Pattern Typology in Consent Banners

In addition to automated technical checks, a manual visual inspection of the benchmark dataset's consent banners was performed to identify the deceptive design methods used to secure data extraction. The most common Dark Pattern found throughout the 15 domains was Visual Interference, which was paired with Click Fatigue.

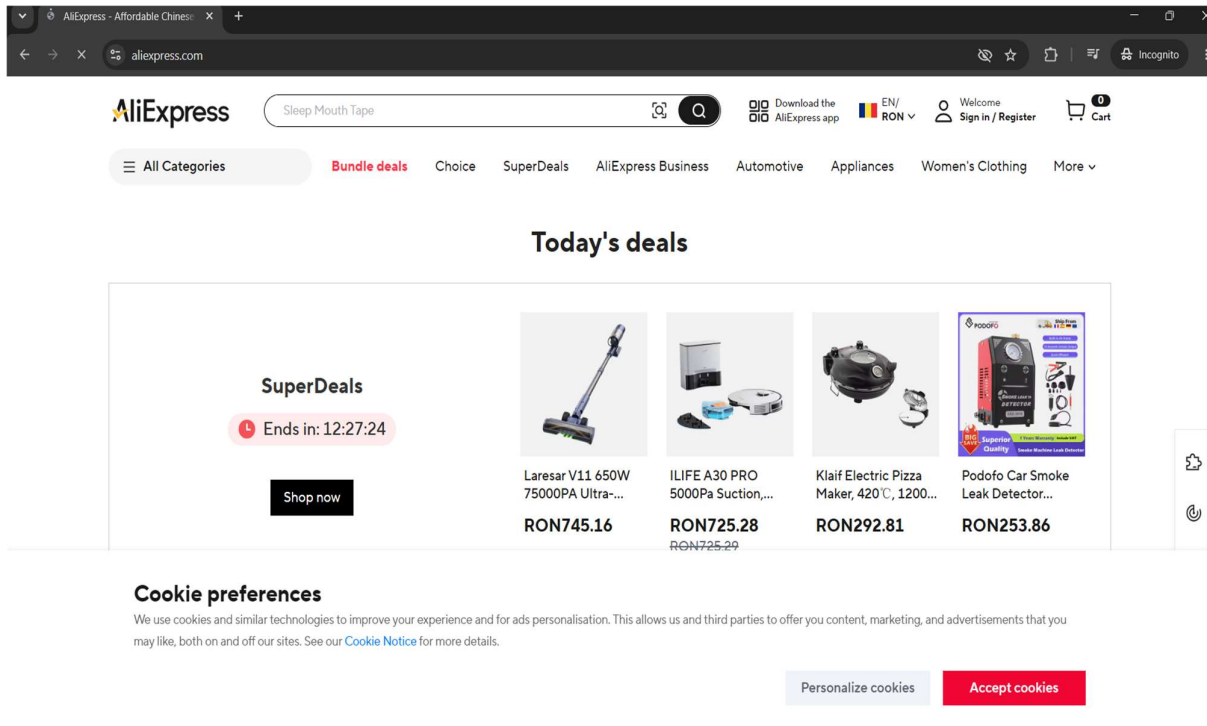


Figure 4. Example of Visual Interference and obstruction utilized within a Consent Management Platform.

As seen in Figure 4, companies heavily manipulate contrast ratios and visual layout to push users toward accepting tracking. This kind of design takes advantage of human cognitive biases. Users naturally want to take the path of least resistance so they can access the website's content as quickly as possible. This creates a very unfair setup. While accepting all cookies takes just one quick click, rejecting them often forces the user to dig through confusing "Vendor Preferences" or "Legitimate Interest" menus. The whole process is designed to cause consent fatigue, leading to artificially high opt-in rates that don't actually reflect what the user wants. Making it significantly harder to reject tracking directly violates the GDPR's rule that withdrawing consent should be as easy as giving it.

5. Discussion

5.1 Synthesis of Empirical Findings

There is a significant systemic gap between written regulatory compliance and technical execution, according to the empirical data collected by the Privacy Policy Analyzer & Cookie Trax tool. While the dynamic browser auditing (Chapter 4.3) showed that these claims are often performative, the static textual analysis (Chapter 4.2) showed that corporations are highly skilled at producing GDPR-compliant legal documentation—often emphasizing "User Rights" and "Transparency."

The main conclusion of this study is that "compliance theater" is currently pervasive in the digital ecosystem. Consent Management Platforms (CMPs) are often used as UI friction points intended to secure data extraction while creating the appearance of legal compliance, rather than serving as genuine interfaces for user autonomy (Utz, et al., 2019) (see Figure 4 for an example of this UI friction). This phenomenon is best highlighted by breaking down the architectural edge cases uncovered during the dynamic auditing phase.

5.2 Architectural Evasion: The Illusion of Consent

By comparing the state of the user interface (the consent banner) to the live Document Object Model (DOM) and browser storage APIs, the application's discrepancy engine discovered three unique technical tactics used by domains to overcome user privacy protections.

5.2.1 Fabricated Consent States and Dark Patterns (Temu)

A clear illustration of misleading user interface design overpowering user intent can be found in the audit of the e-commerce platform Temu (www temu.com). 14 active tracking cookies that were injected prior to consent were found by the program. More importantly, as seen in the DOM diagnostic in Figure 3, the discrepancy engine found that the internal HTTP consent record (`privacy_setting_detail`) was pre-initialized to a "Accepted" state prior to the user interacting with the page.

The platform retained all 14 tracking cookies and refused to modify the `privacy_setting_detail` variable when the "Reject All" method was specifically enabled. This is a deliberate design decision from the perspective of business informatics. The underlying technical design is well-optimized for continuous data collection, explicitly violating GDPR, while the banner is disconnected from the data collection pipeline and only serves to mimic compliance for basic regulatory inspections. Article 7.

5.2.2 Evasive Local Storage Architectures (TikTok)

The evaluation of TikTok (www.tiktok.com) illustrates the ongoing "arms race" between privacy regulations and data aggregators. As browsers increasingly restrict third-party HTTP cookies by default, sophisticated platforms move their tracking vectors to HTML5 Web Storage APIs (`localStorage` and `sessionStorage`).

The program discovered that TikTok almost entirely avoids traditional HTTP cookies by initializing 52 local storage tracking entries before authorization (Urban, et al., 2020). Furthermore, explicitly rejecting consent resulted in a payload that was nearly identical (57 active elements). This architectural change demonstrates the inadequacy of antiquated compliance systems that mostly check for HTTP cookies. TikTok uses local storage to successfully hide its tracking payload from standard regulatory scrutiny while maintaining a consistent stream of user behavioral data.



The shift to HTML5 Web Storage introduces a far more severe privacy threat due to data permanence. Unlike traditional HTTP cookies, which have strict, built-in expiration dates and can be easily cleared by the user via standard browser settings, localStorage has no automatic expiration. Data written to local storage remains on the user's device indefinitely until it is explicitly cleared by the user's manual intervention or targeted JavaScript commands. By migrating their tracking IDs to this architecture, platforms like TikTok create 'zombie trackers' that persist across browsing sessions, silently bypassing both cookie blockers and the GDPR's mandates regarding data retention limits.

5.2.3 Unverifiable Architectures and Ignored Opt-Outs (Meta and OpenAI)

A subtle but non-compliant strategy—ignoring opt-out signals and depending on unverifiable server-side systems—was discovered by Meta and OpenAI audits. Declining tracking did not halt the tracking payloads in either scenario; OpenAI contained four analytics entries, whereas Meta employed a single permanent cookie. These were identified by the systems as employing "Unverifiable Consent," and neither local storage nor client-side HTTP headers changed when users interacted with the CMP.

When platforms handle consent states entirely on their backend servers, it creates a "black box" effect. Even if the company claims to honor the user's choice internally, there is no technical way for the user—or an independent auditing tool—to verify that the tracking actually stopped. During the testing phase, I observed that the browser environment remained exactly the same before and after clicking "Reject." This lack of visible state change effectively strips away the user's data autonomy. It forces people to blindly trust the very corporations that profit from their data, which directly contradicts the transparency requirements mandated by the GDPR. This opaque approach makes it practically impossible for individuals to independently confirm if their data rights are being upheld.

5.3 The Economic Drivers of Compliance Theatre: Real-Time Bidding (RTB)

To fully comprehend the systemic and enduring nature of the compliance theater discovered by the discrepancy engine, the underlying financial benefits driving these design decisions must be investigated. The present digital ecosystem is based on Real-Time Bidding (RTB) networks, which are automated algorithmic auctions where user data is broadcast and sold to thousands of advertisers in the milliseconds it takes for a webpage to load. (Veale & Zuiderveen Borgesius, 2022).

The domains under consideration (such as Meta, TikTok, and Temu) do not employ Dark Patterns or misleading local storage techniques as a result of subpar software design; rather, these are deliberate tactics meant to increase earnings. "Privacy by Default" questions the RTB revenue model's basic premise. A platform loses the opportunity to profit from a user's initial page visit when it rigorously adheres to GDPR and waits for explicit, informed consent before beginning tracking. To understand this financial motivation, one must look at the latency requirements of programmatic advertising. The Real-Time Bidding (RTB) auction occurs in the background within milliseconds of a user navigating to a URL. If a platform waits for a user to read a consent banner and actively click 'Accept', the critical window for the initial page-load ad auction is completely lost. By the time the user consents, the page has already rendered, representing a missed monetization opportunity. Therefore, pre-loading trackers and assuming consent is not a technical error, but a calculated feature designed to ensure the user is profiled and monetized instantly upon arrival. For these domains, strict GDPR compliance essentially functions as a financial penalty.

Business risks include creating permission states and pre-initializing tracking payloads, as the Temu case study illustrates. Businesses weigh the financial benefits of ongoing data collecting against the remote possibility of a manual audit by a Data Protection Authority

(DPA) with limited resources. The industry obviously puts the economic interests of the algorithmic ad exchange ahead of the protection of consumers' digital rights, as seen by the widespread non-compliance found during baseline audits. Understanding this economic dynamic makes it easier to see why technical limitations are crucial for maintaining compliance in addition to legal risks.

5.4 Implications for Regulatory Frameworks

The results of this thesis have significant ramifications for future laws pertaining to digital privacy. The information shows that a regulatory framework that relies on company self-reporting and requires the disclosure of privacy policies is ineffective. (Klonick, 2025). Although the GDPR and the ePrivacy Directive have essentially forced businesses to display ads, the fundamental technical techniques employed for data acquisition have largely remained unchanged.

This so-called "compliance theatre" unfairly burdens people. Consent fatigue is a major problem for users, who frequently click "Accept All" to access content without realizing that selecting "Reject" usually results in the same technological consequence. This study empirically shows that the legal framework's premise that Consent Management Platforms (CMPs) are closely connected to data pipelines is essentially incorrect.

Ultimately, this creates a severe 'enforcement gap' between the law as written and the software as executed. Regulatory bodies, such as regional Data Protection Authorities (DPAs), are heavily staffed by legal professionals rather than software engineers. Consequently, their standard auditing practices often revolve around reading a company's privacy policy and verifying the visual presence of a cookie banner. Because regulators largely lack the automated tools required to perform deep, dynamic Document Object Model (DOM) analysis at scale, tech companies are incentivized to invest heavily in a compliant visual surface while maintaining deeply invasive, non-compliant background architectures. The current regulatory framework is fundamentally blind to the technical realities of modern web development.

5.5 The Necessity of Automated Client-Side Auditing

The results of this study really highlight why tools like this are needed from a software engineering perspective. Right now, enforcing privacy laws depends heavily on manual audits carried out by Data Protection Authorities (DPAs). However, these agencies often do not have the staff or resources to manually check the millions of dynamic websites operating every single day. To fix this imbalance, we need to move from just looking at theoretical legal compliance to actually verifying technical compliance.

Tools like the Privacy Policy Analyzer & Cookie Trax help fix this by giving users and researchers real-time diagnostics. By putting auditing tools directly in the browser, we essentially crowdsource the oversight process. When users can instantly see hidden local storage violations for themselves, they become active participants in protecting their privacy. Automatically comparing a site's legal claims against its actual tracking behavior puts real pressure on data controllers, helping to put an end to the industry's reliance on compliance theater.

6. Conclusions

6.1 Summary of Research and Findings

This thesis' primary objective was to investigate the discrepancy between what is written about regulatory compliance and what is actually done in the real world of digital privacy. In order to accomplish this, Privacy Policy Analyzer & Cookie Trax, a user-friendly local browser program, was developed and evaluated on a number of well-known international websites.

The study successfully employed a dual-engine setup: a dynamic browser storage scanner to track real-time tracking data and a static Natural Language Processing (NLP) module to evaluate theoretical privacy claims. The application performed effectively as an automated, real-time compliance checker by merging these two data sources. The empirical results of this study unequivocally demonstrate how much the contemporary web relies on "compliance theatre." The use of Consent Management Platforms (CMPs) frequently reduces the transparency of business data practices, despite the presence of stringent regulations such as the General Data Protection Regulation (GDPR) and the Privacy Directive.

The analysis identified significant issues in the design of the system, including:

- **Fabricated Consent States:** Temu and other domains preconfigure internal HTTP consent records as "Accepted", ignoring specific user opt-out instructions, and proactively inject tracking payloads prior to user engagement.
- **Storage Evasion:** In order to keep the same tracking payloads regardless of the user's consent option, platforms such as TikTok are increasingly using HTML5 Web Storage APIs (localStorage) instead of traditional, easily auditable HTTP cookies.
- **Unverifiable Server-Side Processing:** Because major companies like Meta and OpenAI do not provide client-side verification of consent states, the system is opaque, overlooks clear rejections, and violates GDPR transparency rules.

In the end, this thesis demonstrates that using legal papers alone to evaluate digital privacy is insufficient. The developed application shows that client-side technical auditing is a useful and crucial instrument for empowering internet users and encouraging real data autonomy.

6.2 Technical Limitations of the Developed Application

Although it has some technological restrictions characteristic of client-side browser extensions, the Privacy Policy Analyser & Cookie Trax program successfully identified significant compliance issues. Understanding the extent of the findings requires an awareness of these limitations.

To begin, the static textual analysis employs a keyword-based NLP algorithm that has been optimized for rapid execution on the client side. However, it lacks the depth of semantic understanding provided by Large Language Models (LLMs). As a result, it may struggle with extremely intricate legal terminology or unorthodox policy frameworks. Furthermore, as demonstrated by the Samsung anomaly in Chapter 4, the extraction engine is unable to evaluate policies that are protected by strict "Cookie Walls" or embedded within complex Single-Page Application (SPA) frameworks such as React, where the relevant text is not immediately available in the initial Document Object Model.

Furthermore, the browser's sandbox environment places restrictions on the dynamic storage auditing module. While it successfully keeps an eye on HTML5 local storage and HTTP cookies, it is unable to recognize server-side tracking techniques. Because technologies like Server-to-Server API tracking (like the Meta Conversions API) function outside of the client,

the application's discrepancy engine is unable to identify data gathered using these techniques.

6.3 Future Work and Research Directions

The shortcomings of the current design point to specific paths for further business informatics research and development. The following improvements could be made to the application in future iterations:

- **Integration of On-Device Machine Learning:** Using WebGPU technology, lightweight, on-device Large Language Models can improve the static text analyser. Since the text stays on the device and is not transferred to external cloud servers, this update would allow the program to perform deep semantic analysis on privacy policies while protecting user privacy.
- **Automated Regulatory Reporting:** A public metrics database could be added to the application. The discrepancy engine is capable of automatically sending standardized compliance notifications to local Data Protection Authorities (DPAs) upon detection of significant General Data Protection Regulation (GDPR) violations, such as tracking prior to obtaining consent or disregarding opt-out requests. This method facilitates proactive rather than reactive enforcement.
- **Global Privacy Control (GPC) Integration:** Future updates should incorporate support for emerging automated consent systems, including the Global Privacy Control signal (World Wide Web Consortium, 2026). This enhancement would enable the extension to automatically reject tracking at the browser header level prior to the loading of Consent Management Platforms (CMPs).

6.4 Final Concluding Remarks

By establishing a solid theoretical framework for data protection, the GDPR's implementation represented a major step forward for digital human rights. However, in a world where the severe commercialization of personal data predominates, regulation alone is insufficient. Reactive regulators or overworked users cannot be the only ones responsible for enforcement when businesses employ more sophisticated Dark Patterns and covert tracking technologies to seem compliant.

This study highlights a critical paradigm change that is required in the field of privacy engineering. Users need to be given automatic, localized auditing tools in order to deal with compliance theatre. Applications like the one created in this thesis represent the crucial development of digital self-defence by bridging the gap between legal theory and software engineering, ensuring that "Privacy by Default" transforms from a legal ideal into a verifiable technical reality.

References

- Adhikari, A., Das, S. & Dewri, R., 2025. Natural Language Processing of Privacy Policies: A Survey. *arXiv preprint*, pp. 1-27.
- Al-Rousan, T., Al-Shargabi, B. & Abualese, H., 2019. A New Security Model for Web Browser Local. *International Journal of Advanced Computer Science and Applications*, 10(8), p. 227–233.
- Barth, A., 2011. The HTTP state management mechanism, RFC 6265. *Internet Engineering Task Force (IETF)*.
- Castro, M., 2021. Understanding and Using Web Workers. *CODE Magazine*, January/February.
- Englehardt, S. & Narayanan, A., 2016. *Online Tracking: A 1-million-site Measurement and Analysis*. New York, Association for Computing Machinery, pp. 1388-1401.
- European Parliament and Council of the European Union, 2002. Directive 2002/58/EC of the European Parliament and of the Council of 12 July 2002 concerning the processing of personal data and the protection of privacy in the electronic communications sector (Directive on privacy and electronic communications). *Official Journal of the European Union*, pp. 37-44.
- European Parliament and Council of the European Union, 2016. Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons about the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC. *Official Journal of the European Union*, pp. 1-88.
- Google, 2026. *Migrate to Manifest V3*. [Online] Available at: <https://developer.chrome.com/docs/extensions/develop/migrate>
- Gray, C. M. et al., 2018. *The Dark Side of UX Design (Patterns)*. Montreal, s.n., pp. 1-14.
- Klonick, K., 2025. BAN COOKIE BANNERS: A CASE STUDY IN TECH. *Harvard Journal of Law & Technology*, 39(1), pp. 1-37.
- Kocyigit, E., Rossi, A. & Lenzini, G., 2023. Towards Assessing Features of Dark Patterns in Cookie Consent Processes. In: *Privacy and Identity Management*. s.l.:s.n., pp. 165-183.
- Ling, Y. et al., 2022. *Are they Toeing the Line? Diagnosing Privacy Compliance Violations among Browser Extensions*. Rochester, s.n., pp. 1-12.
- Matte, C., Bielova, N. & Santos, C., 2020. *Do Cookie Banners Respect My Choice? : Measuring Legal Compliance of Banners from IAB Europe's Transparency and Consent Framework*. San Francisco, s.n., pp. 767-781.
- Mowery, K. & Shacham, H., 2012. Pixel Perfect: Fingerprinting Canvas in HTML5. *Proceedings of the Web 2.0 Security and Privacy Workshop*.
- Nouwens, M. et al., 2020. *Dark Patterns after the GDPR: Scraping Consent Pop-ups and Demonstrating their Influence*. Honolulu, HI, USA, s.n., pp. 1-13.
- Rodriguez, J. D. & Posegga, J., 2018. *CSP & Co. Can Save Us from a Rogue Cross-Origin Storage Browser Network! But for How Long?*. Tempe, AZ, USA, s.n., pp. 170-172.



- Sanchez-Rola, I., Santos, I. & Balzarotti, D., 2017. *Extension Breakdown: Security Analysis of Browser Extension Resources Control Policies*. Vancouver, BC, Canada, s.n., pp. 1-17.
- Soe, T. H., Nordberg, O. E., Guribye, F. & Slavkovik, M., 2020. *Circumvention by design - dark patterns in cookie consent for online news outlets*. Tallinn, Estonia, s.n., pp. 1-12.
- Trevisan, M., Traverso, S., Bassi, E. & Mellia, M., 2019. 4 Years of EU Cookie Law: Results and Lessons Learned. *PROCEEDINGS ON PRIVACY ENHANCING TECHNOLOGIES*, 2019(2), pp. 126-145.
- Urban, T., Degeling, M., Holz, T. & Pohlmann, N., 2020. *Beyond the Front Page: Measuring Third-Party Dynamics in the Field*. Taipei, Taiwan, Association for Computing Machinery, pp. 1275-1286.
- Utz, C. et al., 2019. *(Un)Informed Consent: Studying GDPR Consent Notices in the Field*. New York, Association for Computing Machinery, pp. 973-990.
- Veale, M. & Zuiderveen Borgesius, F., 2022. Adtech and Real-Time Bidding under European Data Protection Law. *German Law Journal*, 23(2), p. 226–256.
- Wilson, S. et al., 2016. *The Creation and Analysis of a Website Privacy Policy Corpus*. Berlin, Germany, Association for Computational Linguistics, pp. 1330-1340.
- World Wide Web Consortium, 2016. *Web Storage (Second Edition)*, s.l.: W3C Recommendation.
- World Wide Web Consortium, 2026. *Global Privacy Control (GPC)*. [Online] Available at: <https://www.w3.org/TR/gpc/>
- Zaeem, R. N. et al., 2020. *PrivacyCheck v2: A Tool that Recaps Privacy Policies for You*. Virtual Event Ireland, s.n., pp. 3441-3444.



Appendices

Appendix: Core Application Code Snippets

This appendix provides select source code snippets from the *Privacy Policy Analyser & Cookie Trax* browser extension to demonstrate the underlying software engineering methodology and logical architecture. The application is built in accordance with Google's Manifest V3 framework, using vanilla JavaScript for localized, client-side execution to ensure strict data minimization.

Appendix 1. Contextual Natural Language Processing (NLP) via Web Workers

The following snippet from `analyzer-worker.js` demonstrates the asynchronous text-parsing engine. It utilises a Web Worker to prevent UI thread blocking and applies contextual awareness by scanning for negation keywords before applying a risk penalty to the privacy score.

```
/**
 * Privacy Policy Analyser - Web Worker
 * Runs analysis in background thread to keep UI responsive
 * Handles large policies with chunked processing
 */

// Try to import the analyser functions
try {
  importScripts('analyzer.js');
  console.log('[Worker] analyzer.js loaded successfully');
} catch (error) {
  console.error('[Worker] Failed to load analyzer.js:', error);
  self.postMessage({
    success: false,
    error: 'Failed to load analyzer.js: ' + error.message
  });
}

// Listen for messages from main thread (popup.js)
self.onmessage = async (event) => {
  const { id, text, action } = event.data;

  console.log(`[Worker] Received message - ID: ${id}, Action: ${action}, Text length: ${text ? text.length : 0}`);

  try {
    if (action === 'analyze') {
      // Verify analyser function exists
      if (typeof analyzePrivacyPolicy !== 'function') {
        throw new Error('analyzePrivacyPolicy function not found');
      }

      // If text is very large, process in chunks
      if (text.length > 100000) {
        console.log('[Worker] Large text detected, processing in chunks...');

```

```

        const results = await analyzeInChunks(text);
        self.postMessage({
            id,
            success: true,
            result: results,
            mode: 'chunked'
        });
    } else {
        // Small text - analyse directly
        console.log('[Worker] Analyzing text directly...');
        const result = analyzePrivacyPolicy(text);
        self.postMessage({
            id,
            success: true,
            result,
            mode: 'direct'
        });
    }
} else {
    self.postMessage({
        id,
        success: false,
        error: 'Unknown action: ' + action
    });
}
} catch (error) {
    console.error('[Worker] Error:', error);
    self.postMessage({
        id,
        success: false,
        error: error.message
    });
}
};

/**
 * Analyse large text in chunks to prevent timeout
 * @param {string} text
 * @returns {object} Merged analysis result
 */
async function analyzeInChunks(text) {
    const CHUNK_SIZE = 50000;
    const chunks = chunkText(text, CHUNK_SIZE);

    console.log(`[Worker] Processing ${chunks.length} chunks...`);

    let processedChunks = 0;

    const chunkResults = chunks.map((chunk, index) => {
        const result = analyzePrivacyPolicy(chunk.chunk);

```



```

    processedChunks++;

    // Send progress update every 5 chunks
    if (processedChunks % 5 === 0) {
        self.postMessage({
            type: 'progress',
            processed: processedChunks,
            total: chunks.length,
            percentage: Math.round((processedChunks / chunks.length) * 100)
        });
        console.log(`[Worker] Progress: ${processedChunks}/${chunks.length}`);
    }

    return result;
});

console.log('[Worker] Merging chunk results...');

return chunkResults.length > 0 ? chunkResults[0] : { score: 0, metrics: {} };
}

```

Appendix 2. Dynamic Cookie Auditing and Discrepancy Engine

The following snippet from `cookie-analyzer.js` illustrates the real-time DOM auditing module. It leverages the Chrome Cookies API to extract the live tracking payload and cross-references it with the established NLP score to detect "compliance theatre".

```

static assessRisk(categorized, consentStatus, bannerActive = false, previousAnalysis
= null, userRejected = false) {
    let riskScore = 0;
    let riskLevel = 'LOW';
    let complianceStatus = 'COMPLIANT';
    let explanation = '';
    const hasTrackingCookies = categorized.tracking.length > 0 ||
                                categorized.analytics.length > 0 ||
                                categorized.advertising.length > 0 ||
                                categorized.social.length > 0;
    if (hasTrackingCookies && bannerActive && consentStatus.found &&
        consentStatus.accepted === null) {
        const count = categorized.tracking.length + categorized.analytics.length
+
        categorized.advertising.length + categorized.social.length;
        riskLevel = 'HIGH';
        complianceStatus = 'NON-COMPLIANT';
        explanation = `Pre-consent tracking detected: ${count} tracking/social
cookies are active while the consent banner is still showing. The consent cookie
('${consentStatus.cookieName}') was found, but its value could not be verified – this
violates GDPR.`;
    }
}

```

```
else if (hasTrackingCookies && userRejected && consentStatus.found &&
consentStatus.accepted === true) {
    riskLevel = 'HIGH';
    complianceStatus = 'NON-COMPLIANT';
    const count = categorized.tracking.length + categorized.analytics.length
+ categorised.advertising.length;
    Explanation = `Consent choice not honoured: You clicked reject, but
${count} tracking cookies remain active, and the consent cookie is still set to
"accepted" – your rejection was ignored. This violates GDPR.`;
}
else if (hasTrackingCookies && userRejected && !bannerActive) {
    const count = categorized.tracking.length + categorized.analytics.length
+
    categorized.advertising.length + categorized.social.length;
    riskLevel = 'HIGH';
    complianceStatus = 'OPT-OUT IGNORED';
    explanation = `Tracking continues after rejection: You declined cookies
but ${count} tracking/social cookies are still active. The site does not honour opt-
out choices – this violates GDPR Article 7.
}
return { score: normalizedScore, level: riskLevel, complianceStatus, explanation };
}
```

